

22

Compliance in Clouds

Thorsten Humberg and Jan Jürjens

Fraunhofer Institute for Software and Systems Engineering, Germany

22.1 Introduction

The requirement to ensure security and compliance of systems and processes has become an important consideration when leveraging information technology for business operations. Violations of compliance requirements can have serious consequences, including legal and contractual penalties, loss of business growth, and loss of reputation among customers.

Ensuring and managing compliance is a complex multidisciplinary challenge (Rath and Sponholz, 2009). It incorporates the management of, for example, general legal regulations, IT-specific standards and planning, and management of business processes within a company. We will provide an overview of general as well as IT-related compliance and security regulations in section 22.2.

Cloud-based services have seen a rapid growth in popularity in recent years. The cloud has significant potential in terms of increased efficiency of IT administration while reducing costs. Nevertheless, many companies are reluctant to outsource existing services to cloud providers, largely due to the concerns regarding security and compliance issues. In this chapter, we address these concerns and introduces the concept of certificates as a means to evaluate service providers with respect to their compliance.

22.2 IT-Related Compliance

The term “compliance” is not specific to the information technology (IT) context, and can be defined differently depending on the way it is approached. In its broadest sense, it means adherence to regulatory specifications of any kind.

From a commercial perspective, the frequently encountered financial and accounting issues related to compliance requirements are predominantly from the Sarbanes-Oxley Act (SOX) and the Gramm–Leach–Bliley Act (GLB). Such regulations do not address information technology aspects directly but IT plays an important role in providing the necessary means to implement the requirements (Herrmann, 2007).

In addition to these general requirements, businesses in some domains are subject to specific regulations, like the Health Insurance Portability and Accountability Act (HIPAA) for the healthcare domain.

As per the general definition, “IT compliance” means the implementation and operating of IT systems according to the relevant regulations. Those might be the general requirements mentioned above if information technology is used in their implementation, or IT-specific regulations, for example regarding security aspects.

The IT compliance regulations that have recently seen a significant rise in public awareness are those concerning data privacy. These regulations are a complex field in themselves, as they strongly depend on the jurisdiction where IT infrastructure is located, which can lead to inconsistent or even conflicting requirements (Mather *et al.*, 2009). The dynamic nature of the physical distribution of data in cloud computing environments further complicates this problem.

IT-relevant compliance regulations can be divided into four groups, depending on their scope and issuer (Strasser and Wittek, 2012):

- Legal regulations and laws, issued by a public authority, which have an effect on IT. Typically, the regulations in this category concern IT aspects only indirectly, like the Sarbanes–Oxley Act mentioned above.
- Contracts with suppliers or customers, either concerning IT aspects explicitly, or merely influencing them.
- Internal regulations, issued by the company itself. This includes procedures and regulations established in order to meet external requirements. For example, creating and deploying a policy for the use of passwords is a compliance requirement in implementing the information security standard ISO 27002. Many companies define their own ethical codes as a high-level orientation for their personnel.
- External regulations, such as standards and best practices, which were not issued by an official legislative authority. Examples are standards by the ISO and equivalent organizations. The significant compliance regulations related to security standards and certificates are discussed in section 22.4.

22.3 IT-Compliance in Cloud Environments

Cloud services can be considered as an additional layer on top of a classic IT infrastructure. This means that compliance and security for clouds can only be achieved if the underlying systems are compliant and secure in themselves. Compliance, especially when it comes to personally identifiable information (PII), is in many cases concerned with the restriction of access to certain types of data. In cases where an attacker can gain control over the systems processing the data, the attacker can access any cloud software running on them directly and the restrictions cannot hold. This implies that information security is an important prerequisite for IT-compliance.

The extra layer introduced by cloud software can also raise new issues regarding compliance, some of which will be presented in this section.

In order to achieve compliance, it is necessary to define clearly the kind of data that is processed by the service, who is allowed to access them, and for what purposes. With cloud service providers, and possibly even more subcontractors, more stakeholders are involved in storing and processing data, leading to an increased need to define and enforce rules regarding ownership and accountability of data.

In general, it is the cloud customer’s responsibility to make sure that data is handled in an appropriate way. A cloud service provider (CSP) often does not even have enough knowledge about the kind of data stored and processed by its customers to determine which compliance regulations are applicable (Golden, 2010). It is therefore not realistic to expect the CSP to offer a guarantee for compliance, or take responsibility for it.

To ensure that a cloud service provider is sufficiently reliable to be chosen, it is generally necessary for the customer to thoroughly evaluate the level of compliance and security the CSP offers. But in most cases, the actual systems of the provider are inaccessible for the end user, and thus cannot be assessed by him directly. The dynamic nature of resource provisioning in cloud concepts makes assessments by individual customers even more impractical. Furthermore, the CSP that the customer interacts with might work with even more subcontractors. For example, a common business model is for providers of SaaS solutions to host their services on systems that are themselves rented from an IaaS provider.

From the customer's perspective, one of the benefits of the cloud concept is flexibility in choosing the provider, which contrasts with the need to invest much effort into assessing individual cloud providers for their respective compliance levels.

Both problems can be mitigated by the use of certificates for approved compliance standards, as discussed in the next section.

In cloud environments, compliance issues arise from the physical locations of servers, which could be opaque to the end user. Especially for data privacy regulations, physical locations of servers play an important role. Inappropriate locations can violate certain requirements in themselves, but can also lead to more regulations becoming applicable. Again, this problem is intensified when subcontractors are involved, whose data-centers' locations might not be known or restricted appropriately. A common way to handle this concern is to define acceptable locations or regions in the SLA of the particular service explicitly.

So far, we have considered a number of reasons that complicate security and compliance management in cloud environments. The implication would be that staying with the traditional model of internal IT infrastructure (or at most a cloud following the private cloud deployment model) is the superior approach. This is not necessarily the case.

Maintaining security and compliance for any IT environment is a challenging, time-consuming, and thus expensive task. Neglecting this task, for example by not being able or willing to provide the resources necessary, generally leads to insecure systems.

On the other hand, the cost scales well with larger systems: the bigger the IT infrastructure, the more efficiently security can be handled. This is the point where cloud concepts can lead to a gain in security and compliance. By offering similar setups to a number of customers, a cloud service provider can develop and apply a sophisticated security concept to a (possibly large) number of systems in a standardized way.

Whether using a cloud service will lead to an increase or decrease in security strongly depends on the actual case at hand. In particular, the question of which requirements have to be met at all strongly depends on the way a customer would use the services.

22.4 Security Standards and Certificates

Within the context of information technology, and especially regarding information security and compliance, certificates are an established mechanism to create trust between a provider and its (potential) customers.

Note that in the field of information technology, the term "certificate" is ambiguous. In this article, we use it to mean a way to assure compliance with a given regulatory standard. We use it neither in its cryptographic context, nor as a proof of personal qualification.

For cloud computing, the concept of certificates can be used to mitigate some of the problems that arise in terms of IT compliance. In most cases, a customer has little to no opportunity to examine the cloud service provider's facilities or its business processes thoroughly. Nevertheless, he is responsible for choosing a provider that offers a sufficient level of security and compliance. An appropriate certificate can be a way to offer the trust needed.

Obtaining a certificate can also be beneficial for the CSPs themselves, despite the substantial effort involved on their part. By obtaining a certificate, they can avoid discussing their security measures with each individual customer and also eliminate the need to disclose confidential internal details, or data of other customers, in order to provide assurance of security levels (Mather *et al.*, 2009).

Certificates can even be a prerequisite for using a service for specific business activities at all. A prominent example is the Payment Card Industry Data Security Standard (PCI DSS) that every company has to implement in order to be allowed to process credit card payments (PCI Security Standards Council, 2013).

Certificates can roughly be distinguished with regard to their domains:

- general information security standards and certificates;
- cloud-specific certificates;
- domain-specific certificates.

The distinction cannot always be clearly drawn, one reason being that cloud services are based on traditional IT infrastructure, as described above, and must thus adhere to general security requirements. Which standards are relevant for a CSP or its customers depends on the intended use. Some examples for the different categories will be given below.

22.4.1 General Information Security Standards and Certificates

Most regulations and standards for information technology systems are not specific to cloud environments, but are relevant to the IT systems they are based on. Probably the most commonly acknowledged standards are those of the ISO 27000 series, which cover different aspects of information security. ISO 27001 describes how an information security management system (ISMS) can be established (ISO/IEC, 2013). It also includes a set of controls that can be implemented in order to mitigate risks for an IT system; those controls are further detailed in standard ISO 27002.

Certification according to ISO 27001 is a common requirement for a provider to guarantee an adequate level of security. It is issued by accredited third-party certification bodies (ISO/IEC, 2014). How audits are to be performed is specified in a separate standard, ISO 19011 (ISO/IEC, 2011).

22.4.2 Cloud-Specific Standards and Certificates

As discussed above, using the cloud computing model for outsourcing of IT resources imposes additional concerns regarding security and compliance. In order to open up its possibilities, nonetheless, several organizations have proposed a number of cloud-specific standards. For some of those standards, corresponding certificates can be issued.

22.4.2.1 FedRAMP (*Federal Risk and Authorization Management Program*)

In line with the Federal Cloud Computing Strategy, US federal government agencies use cloud computing resources to reduce costs for IT services. The FedRAMP standard is intended to define a consistent level of information security for cloud service providers that is sufficient for federal agencies to use these services in particular applications (Figliola and Fischer, 2014). Compliance with FedRAMP has to be evaluated by an accredited third-party assessment organization (3PAO) (US General Services Administration, 2014).

22.4.2.2 *Security, Trust and Assurance Registry (STAR)*

The Cloud Security Alliance (CSA) has developed STAR to establish a registry of cloud service providers that offer specified levels of security. STAR defines three stages of certification, based on the Open Certification Framework, which has also been developed by the CSA (Cloud Security Alliance, 2014):

- STAR Entry – Self Assessment: providers answer a questionnaire, which is then published by the CSA.
- STAR Certification: the certification is granted by a third-party assessment organization (3PAO); the necessary criteria are based on those needed for an ISO 27001 certificate.
- STAR Continuous: the third stage requires a continuous monitoring of the CSP's security, based on the CSA Cloud Trust Protocol (CTP).

22.4.2.3 *Cloud-Specific ISO Standards*

In addition to the general security standard ISO 27001, several cloud-specific standards are currently under development:

- ISO 27017: *Information Technology – Security Techniques – Code of Practice for Information Security Controls for Cloud Computing Services based on ISO/IEC 27002.*
- ISO 27018: *Information Technology – Security Techniques – Code of Practice for PII Protection in Public Cloud Acting as PII Processors.*
- ISO 27036-4: *Information Technology – Information Security for Supplier Relationships – Part 4: Guidelines for Security of Cloud Services.*

These documents are not redundant to other standards of the ISO 27000 series but extend those by cloud-specific controls.

22.4.3 *Domain-specific certificates*

For some domains, there exist specific standards that any company has to implement and verify in order to act in that field. If a cloud customer intends to use a cloud service provider to perform such tasks, or the CSP plans to offer services directed at such a domain, those certificates have to be established.

A common example is the Payment Card Industry Data Security Standard (PCI DSS), which is required for systems that handle credit-card transaction data.

Similarly, US companies involved in the healthcare domain have to adhere to the Health Insurance Portability and Accountability Act (HIPAA).

22.4.4 *Examples of Certificates offered by Cloud Service Providers*

This section gives an overview of the current situation of popular cloud service providers regarding the information security and compliance certificates they offer. We focus on those certificates that have been presented in the previous sections.

Note that even though a CSP might meet the requirements of a specific standard, this does not imply that every usage of those services is secure and compliant as well. As mentioned in section 3, and stressed by the CSPs themselves, certification only relates to the underlying infrastructure and services. Determining whether a given service is compliant to use for a specific purpose is still the responsibility of the cloud user.

When choosing a CSP based on required certification, a customer also has to pay attention to the scope of the certificate. Cloud service providers commonly offer a number of different services. Issued certificates do not necessarily include every one of these services; their scope can instead be restricted to a subset.

In the following paragraphs, we will take three popular providers of IaaS products as examples: Amazon AWS, Microsoft Windows Azure and Google Compute Engine.

Security management, according to ISO 27001, can be regarded as a basic requirement that is fulfilled for the underlying infrastructure of any of the major providers.

All three services also claim to be compliant for healthcare applications subject to the HIPAA standard, although an additional contract in the form of a “business associate agreement” (BAA) has to be signed.

For FedRAMP, CSA STAR Audit and PCI DSS, only the services provided by Amazon AWS and Microsoft Azure have been certified. For STAR, both providers have been certified for the first-stage “STAR Entry – Self Assessment.” For PCI DSS, both have been certified for the highest level 1, sufficient for merchants processing more than 6 million payment transactions per year.

22.5 Conclusion

Identifying the relevant regulations for a given business case and fulfilling the requirements is a complicated task for classic IT systems. The nature of cloud deployment models adds further difficulties:

- More stakeholders are involved, whose responsibilities have to be evaluated and defined. This not only concerns providers directly interacting with the customer but also includes potential subcontractors.
- Actual physical locations of servers and data matters a lot but become harder to determine, verify or restrict to allowed regions. This can lead to the violation of compliance requirements, especially concerning data privacy.
- The cloud provider’s datacenters are generally inaccessible for customers, so they cannot examine its level of security.

On the other hand, using the experience and resources a cloud service provider can offer for establishing security and compliance can lead to an increase in security with little effort from the customer.

By establishing adequate approved certificates, it is also possible at least to mitigate the problem of not being able to access the provider’s facilities. Instead of every customer having to assess a CSP separately, a single certification body asserts that the necessary measures are implemented to ensure an appropriate level of compliance and security.

Most of the existing standards make no assumptions about the computing model of the IT infrastructure used. Several cloud-specific standards have been developed, and more are currently under development. Nevertheless it is still the task of cloud customers to determine which requirements have to be met for their particular applications, and choose appropriate cloud service providers.

Additional Resources

Resources by Cloud Service Providers

Amazon and Microsoft give broad overviews of a number of compliance requirements for their AWS and Azure products, respectively, some of which have been described in this article:

<http://aws.amazon.com/compliance/> (accessed December 22, 2015).

<http://azure.microsoft.com/en-us/support/trust-center/compliance/> (accessed December 22, 2015).

Information for the Google Compute Engine is part of the listed features of the product:

<https://cloud.google.com/products/compute-engine/> (accessed December 22, 2015).

Security and Compliance Standards

ISO 27001 series:

<http://www.iso.org/iso/home/standards/management-standards/iso27001.htm> (accessed December 22, 2015).

FedRAMP, and the NIST standard 800-35 it is based on:

<http://cloud.cio.gov/fedramp> (accessed December 22, 2015).

<http://csrc.nist.gov/publications/PubsSPs.html> (accessed December 22, 2015).

CSA STAR certification and the registry of participating cloud service providers:

<https://cloudsecurityalliance.org/star/certification/> (accessed December 22, 2015).

https://cloudsecurityalliance.org/star/#_registry (accessed December 22, 2015).

Payment Card Industry Data Security Standard (PCI DSS):

https://www.pcisecuritystandards.org/security_standards/ (accessed December 22, 2015).

References

- Cloud Security Alliance (2014) *CSA Security, Trust and Assurance Registry*, <https://cloudsecurityalliance.org/star/> (accessed December 22, 2015).
- Figliola, P. M. and Fischer, E. A. (2014) *Overview and Issues for Implementation of the Federal Cloud Computing Initiative: Implications for Federal Information Technology Reform Management*, s.l. Congressional Research Service, Washington DC.
- Golden, B. (2010) *Data Compliance and Cloud Computing Collide: Key Questions*, http://www.cio.com/article/612063/Data_Compliance_and_Cloud_Computing_Collide_Key_Questions (accessed December 22, 2015).
- Herrmann, D. (2007) *Complete Guide to Security and Privacy Metrics: Measuring Regulatory Compliance, Operational Resilience, and ROI*, Auerbach Publications, Boca Raton, FL.
- ISO/IEC, 2011. ISO 19011:2011 (2011) *Guidelines for Auditing Management Systems*, ISO, Geneva.
- ISO/IEC, 2013. ISO/IEC 27001:2013 (2013) *Information Technology – Security Techniques – Information Security Management Systems – Requirements*, ISO, Geneva.
- ISO/IEC, 2014. (2014) *Certification – ISO*, <http://www.iso.org/iso/home/standards/certification.htm> (accessed December 22, 2015).
- Mather, T., Kumaraswamy, S. and Latif, S. (2009) *Cloud Security and Privacy: An Enterprise Perspective on Risks and Compliance*, O'Reilly Media, Inc., Sebastopol, CA.
- PCI Security Standards Council (2013) *Payment Card Industry Data Security Standard*, Version 3.0, PCI, Wakefield, MA.
- Rath, M. and Sponholz, R. (2009) *IT-Compliance: Erfolgreiches Management regulatorischer Anforderungen*. Erich Schmidt Verlag, Berlin.
- Strasser, A. and Wittek, M. (2012) *IT-Compliance – GI – Gesellschaft für Informatik e.V.*, <https://www.gi.de/service/informatiklexikon/detailansicht/article/it-compliance.html> (accessed December 22, 2015).
- US General Services Administration (2014) *About FedRAMP*, <http://www.gsa.gov/portal/category/102375> (accessed December 22, 2015).